Cybersecurity

Joakim Kävrestad

WHO AM I

- Joakim Kävrestad

- ”Lektor” in computer science
  - Teaching focus is forensics and cybersecurity
  - Research focus is user centred security

- Background
  - ”lektor” and ”adjunct” in Skövde since 2016
  - Forensic expert 2014-2016

TODAY

- Course Introduction
  - Course plan
  - Literature
  - Examination
  - Lab platform

- Topic introduction
  - Penetration testing
  - Incident management and response
  - Forensics

COURSE PLAN

- Explains learning outcomes
  - Demonstrate knowledge about central concepts and standards within cybersecurity
  - Demonstrate knowledge about SOCs and the roles included in a SOC
  - Know about common terms within computer forensics
  - Demonstrate skills in penetration testing (ethical hacking)
  - Demonstrate ability to handle incidents in IT systems
  - Demonstrate ability to conduct simple computer forensic examinations
  - Demonstrate ability to find and present research within the course domain

COURSE PLAN

- Examination and grades
  - Written exam
  - Lab work
  - Seminar

- Graded 3/4/5/U

COURSE LITERATURE

- CyBOK – cybersecurity body of knowledge
  - www.cybok.org
  - Contains sections on many cybersecurity topics
  - We will explore four:
    - *Security Operations & Incident Management.*
    - *Forensics.*
    - *Adversarial Behaviours.*
    - *Malware & Attack Technology.*
  - Other resources for you to explore at will

COURSE ORGANIZATION

- The course is divided into three blocks which will be explored one after the other
  - 1: Penetration testing
  - 2: Incident management and response
  - 3: Cybercrime and digital forensics

- Lecture plan in Canvas
  - Three parts in every topic
    - Methods
    - Tools and trix
    - Research and state of the art
  - NOTE! We will try to go a bit quicker than the plan!

EXAMINATION

- Written exam
  - Cover all content (lectures and literature)
  - Graded 3/4/5/U
  - Done in inspera
  - Determines the course grade

- Seminar
  - Will be about finding and reading scientific papers
  - Graded pass/fail

EXAMINATION

- Lab work
  - One set of labs for each block
  - Block 1 and 2 done through TryHackMe
  - Block 3 done using your lab disks
  - NOTE: Teacher available from 9:00 at lab sessions

- TryHackMe
  - Accessible through a web browser
  - You need to sign up by following the procedure explained on Canvas

TRYHACKME

- Could based cybersec lab platform

- Labs arranged around “learning paths”
  - I have created three for you
    - Platform intro
    - Pentesting
    - Incident response
  - You will get “all access” licenses for two months, feel free to explore as much as you like

Questions?

CYBERSECURITY

- CISA: Cybersecurity is the art of protecting networks, devices, and data from unauthorized access or criminal use and the practice of ensuring confidentiality, integrity, and availability of information.

- CyBOK: : Cyber security refers to the protection of information systems (hardware, software and associated infrastructure), the data on them, and the services they provide, from unauthorised access, harm or misuse. This includes harm caused intentionally by the operator of the system, or accidentally, as a result of failing to follow security procedures.

CYBERSECURITY

- INFORMATION security regards preserving the confidentiality, integrity, and available of information no matter how the information is stored and no matter the nature of risks.

- NETWORK security is mainly concerned with safeguarding the information and functionality within the own network

- CYBER security focuses on adversarial, unauthorized, and misuse events and is concerned with information as well as devices

CYBERSECURITY

I will not ask about definitions of cybersecurity in the exam☺

CYBERSECURITY – A BROAD TOPIC

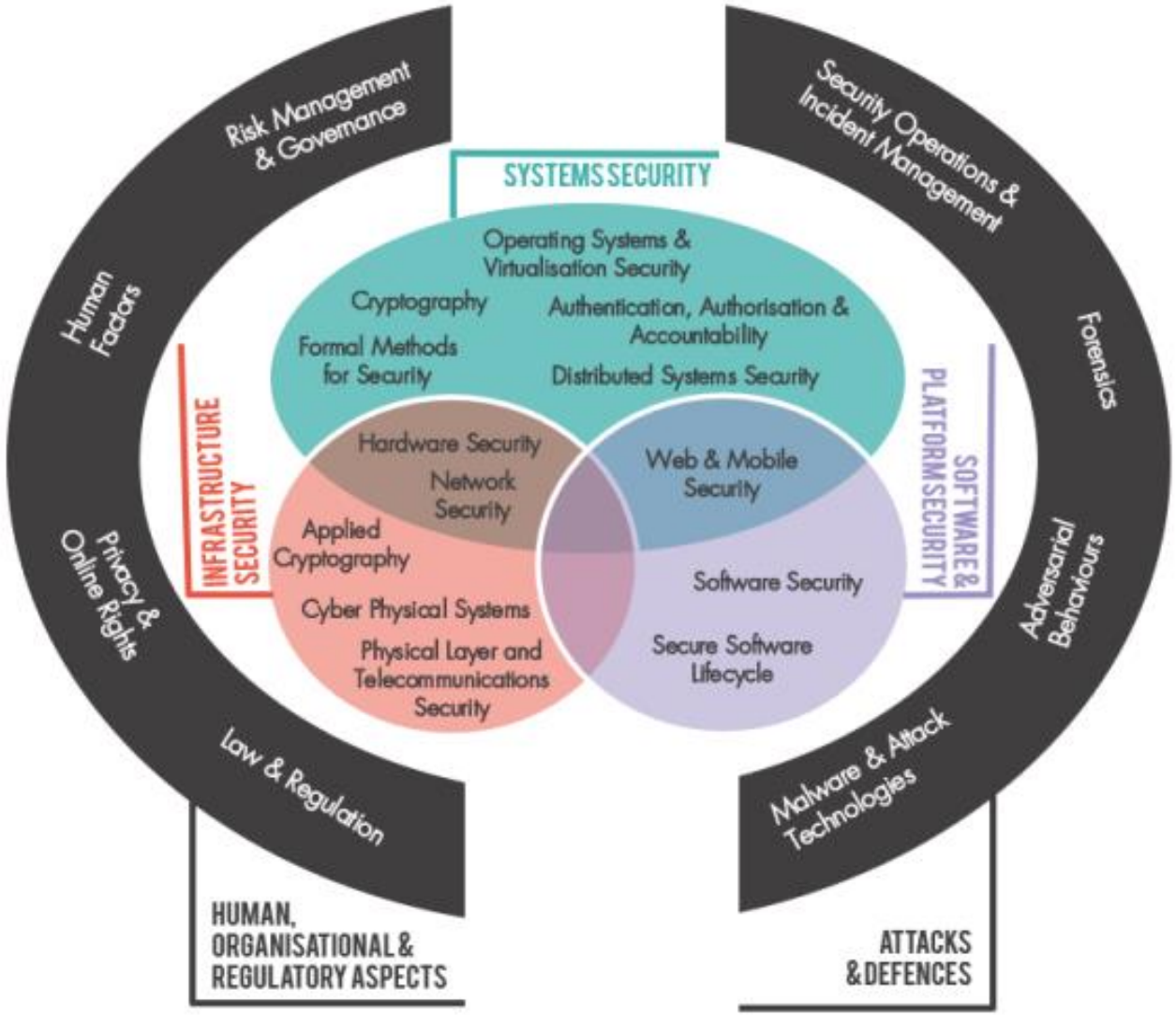

Figure 1: The 21 Knowledge Areas (KAs) in the CyBOK Scope

Questions?

PENETRATION TESTING

Security testing in which evaluators mimic real-world attacks in an attempt to identify ways to circumvent the security features of an application, system, or network. Penetration testing often involves issuing real attacks on real systems and data, using the same tools and techniques used by actual attackers. Most penetration tests involve looking for combinations of vulnerabilities on a single system or multiple systems that can be used to gain more access than could be achieved through a single vulnerability.

NIST-SP 800-115

PENETRATION TESTING OR ETHICAL HACKING

- Terms often used interchangeably
- Some key differences exist
  - Pentesting is often limited in time and scope, while ethical hacking is more of an ongoing process.
  - Pentesting is described as more focused on in-depth knowledge or a single service/area, while ethical hacking is a bit more free
- In this course, we consider them to be the same thing

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

PENTESTING

- Conduct attacks to expose system vulnerabilities and weaknesses
- So well then, hacking
- Very diverse
  - Attempting to exploit a single service
  - Finding any possible way into a network

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

PENTESTING – THE BOXES

- Penetration testing involves pen tests where the pentester has different levels of knowledge about the target systems
  - White box: Full knowledge about the target system
  - Grey box: Partial knowledge
  - Blac box: no knowledge

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

PENTESTING – THE HATS

- Hackers are often classified by their….moral compass
  - Black hat: Crimials who hack with criminal intent
  - Grey hat: Hackers who “do good” according to their own moral compass and without respect for law and ethical standards
  - White hats: Pentesters who remain within the bounds of the law and ethical standards

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

PENTESTING – RULES OF CONDUCT

- As a pentester, we are white hats

- We only perform authorized audits
- We stay within the laws
- We stay within the bounds of our assignments
- We do our best to follow ethical practises

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

PENTESTING – HOW TO GET THEM GIGS

- Pentester as a consultant
- Pentester as hired by a company
- Pentester using bug bounty programs, for instance, through HackerOne

EC-Council. (2021a). CEH vs. PenTest+. *https://www.eccouncil.org/ceh-vs-pentest/*

Reflect:1-2-4-all

Individually (60 Sec): Write core statements (one-liners) about what you learned in the last lecture part.

Pair up and compare lists (60 Sec) (add new things to your individual lists)

Pair the pairs and repeat (60 Sec)

Then one statement per group of four.

INCIDENT MANAGEMENT AND RESPONSE

The mitigation of violations of security policies and recommended practices.

NIST-SP 800-61

INCIDENT MANAGEMENT AND RESPONSE

- Incident handling or response
- *What you do when an incident occurs*
- An incident is *An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use policies*

NIST SP 800-82

INCIDENT MANAGEMENT AND RESPONSE

- To handle an incident you need to be prepared
- So that you know what to do when it is detected
- And after it has been handled

NIST SP 800-82

Reflect:1-2-4-all

Individually (60 Sec): Write core statements (one-liners) about what you learned in the last lecture part.

Pair up and compare lists (60 Sec) (add new things to your individual lists)

Pair the pairs and repeat (60 Sec)

Then one statement per group of four.

CYBERCRIME

- We use the umbrella term *cybercrime* to collectively refer to all crimes related to computer and telecommunications misuse; broadly, these include the use of cyber systems to commit any type of crime, as well as the criminal targeting of cyber systems.

- Cyber dependent crime
  - Actions that require cyber elements
- Cyber-enabled crime
  - Traditional crimes where cyber is used

NIST SP 800-82

DIGITAL FORENSICS

- is the application of scientific tools and methods to identify, collect and analyze digital (data) artifacts in support of legal proceedings

- Relevant in all types of crime where digital devices may hold evidence
  - Online drug sales
  - Sextortion
  - Hacking
  - Murder

NIST SP 800-82

JÖNKÖPING UNIVERSITY

School of Engineering